

Network Security

Theory Class Nº5

Jorge Sa Silva
sasilva@deec.uc.pt
University of Coimbra
Portugal

Outline

- Cryptography
  - Symmetric cryptography
    - Functions
      - Introduction
      - DES
      - AES
  - Hash function
  - Diffie-Hellman



Cryptography



- Perspective:
  - User
  - Manager
  - Developer

Introduction to Cryptography



- Cryptography is the science of using mathematics to encrypt and decrypt data

- Cryptography is important:
  - Data integrity
  - User authentication
  - Information confidentiality

"A good cryptographic algorithm must be based on a balanced compromise between complexity and usability"

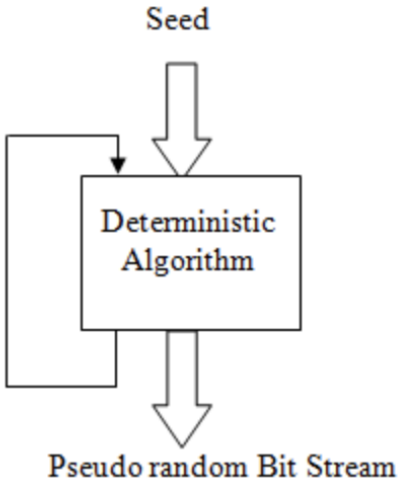
Kerckhoffs's principle

- The security of the encryption scheme must depend only on secrecy of the key and not on the secrecy of the algorithm
- As opposed to "security through obscurity"
- New ciphers and algorithms are not trusted without public scrutiny over years.



Some concepts

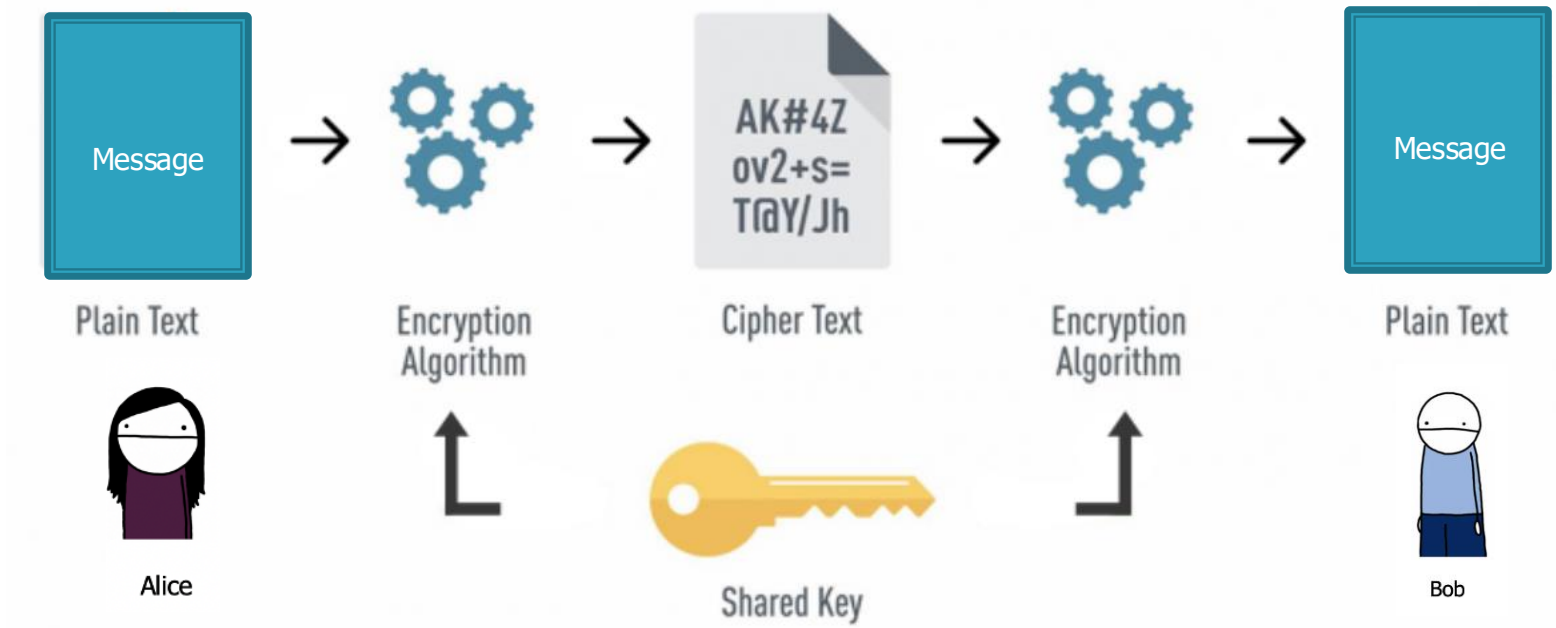
- One-way (irreversible) functions
  - Difficult to apply y=f(x)
  - Ex: m mod n = z
- Random and pseudo-random number generators
  - Problem: period
    - May not be a problem if the seed is not known and the period is large enough
  - Need to restart with (random) seeds



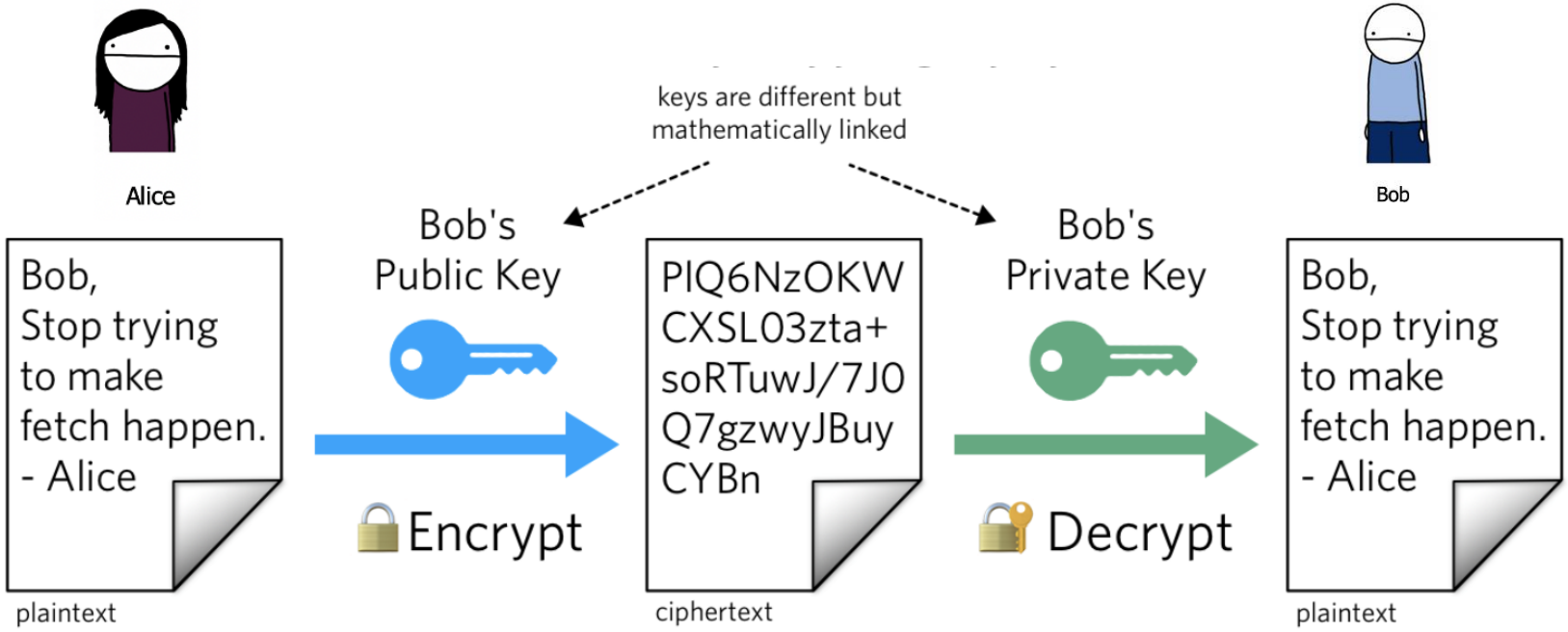
Encryption Strength

- Depends on:
  - Algorithm
  - The secrecy of the key
  - The length of the key
  - The initialization vectors
  - How all work together
- Work factor
  - An estimate of the effort and resources it would take to penetrate a cryptosystem
- Strength of protection mechanism should be based in correlation to the sensitivity of the data being encrypted.

Symmetric Encryption

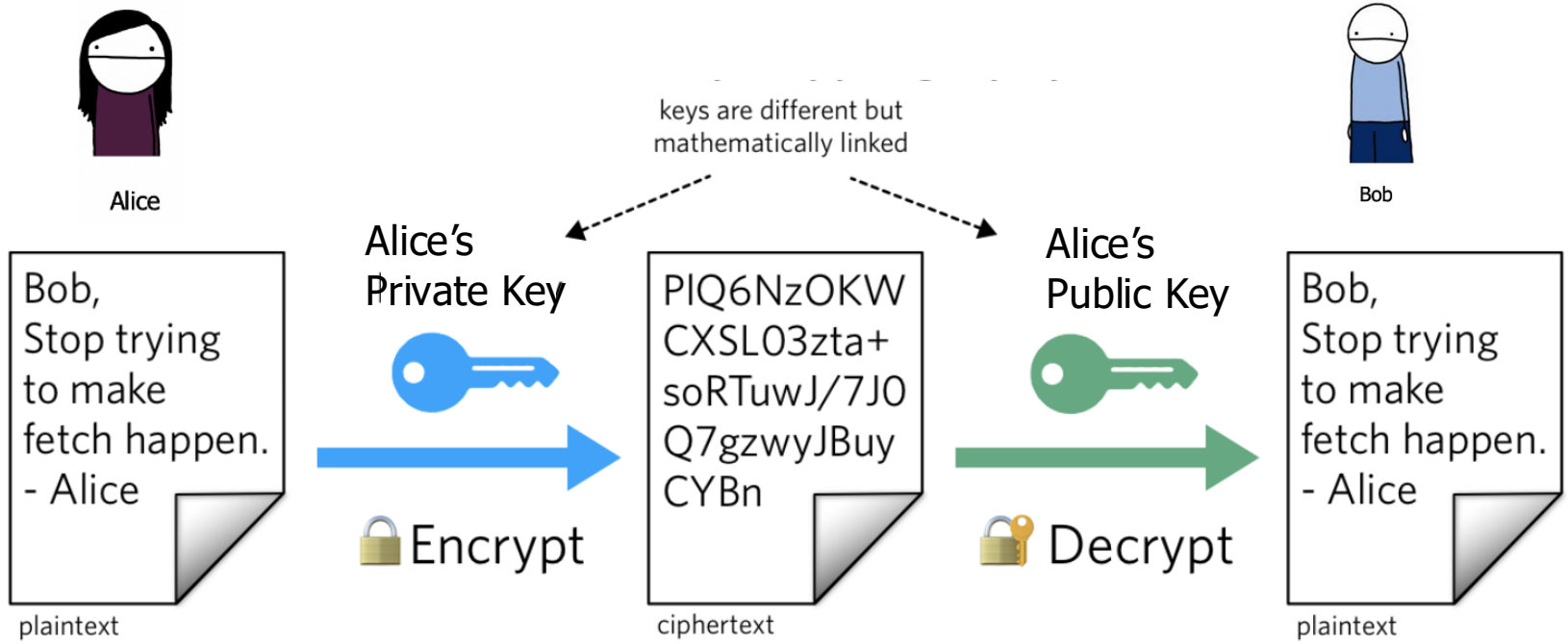


Asymmetric Encryption (confidentiality)



Only Bob can read the message!

Asymmetric Encryption (authentication)



Symmetric vs Asymmetric

- Asymmetric encryption requires more computational power
- Asymmetric encryption can be used to distribute symmetric keys
- Symmetric keys should be reset from time to time

Cryptanalysis and Brute – Force Attacks

- Objective of attacker: recover key (not just message)
- Approaches of attacker:
  - Cryptanalysis: Exploit characteristics of algorithm to deduce plaintext or key
  - Brute-force attack: Try every possible key on ciphertext until intelligible translation into plaintext obtained
- Important note: if attack succeeds, all future/past messages are compromised



Symmetric Encryption

Classic techniques

(Before computer age…)

- Substitution techniques
- Transposing techniques

Substitution techniques

- Letters of plaintext are replaced by others letters or by numbers of symbols
- Examples:

1. Caesar Cipher

- Earliest known cipher, used by Julius Caesar (Roman general 2000 years ago)
- Replace each letter by the letter three positions along in alphabet

Plain : a b c d e f g h i j k l m n o p q r s t u v w x y z
Cipher: D E F G H I J K L M N O P Q R S T U V W X Y Z A B C

2. Generalised Caesar Cipher

- Allow shift by k positions
- Assume each letter assigned number (a = 0, b = 1, . . .)

  $C = E(k; p) = (p + k) \bmod 26$

  $p = D(k; C) = (C - k) \bmod 26$

Substitution techniques

3. Atbash cypher

- ”The Da Vinci code”

a b c d e f g h i j k l m
z y x w v u t s r q p o n

4. Monoalphabetic cypher

- Use a single alphabet for both plaintext and ciphertext
- Arbitrary substitution: one element maps to any other element
- n element alphabet allows n! permutations or keys
- Example:

Plain : a b c d e ... w x y z
Cipher: D Z G L S ... B T F Q

-> Theoretical: 26!
-> Real: << 26!

- Regularities of the language
- Frequency of letters, diagrams, trigrams
- Expected words

Substitution techniques

4. Polyalphabetic cypher

- Use a set of characters for both plaintext and ciphertext
- Example:

Plain : ab ac ad ae ...
Cipher: ND UZ PO LI ...

5. Vigenère cypher

- Set of 26 general Caesar ciphers
- Letter in key determines the Caesar cipher to use
- Key must be as long as plaintext: repeat a keyword
- Example:

Plain: internettechnologies
Key: sirindhornsirindhorn
Cipher: AVKMEQLHKRUPEWYRNWVF

- Multiple ciphertext letters for each plaintext letter

Substitution techniques

6. One-time pad

- Similar to Vigenere, but use random key as long as plaintext
- Perfect secrecy! – only known scheme that is unbreakable (unconditional security)
- Ciphertext has no statistical relationship with plaintext
- Given two potential plaintext messages, attacker cannot identify the correct message
- Two practical limitations:
  - Difficult to provide large number of random keys
  - Distributing unique long random keys is difficult
- Limited practical use

One-time pad

ENCRYPT

	0 0 1 1 0 1 0 1	Plaintext
⊕	1 1 1 0 0 0 1 1	Secret Key
=	1 1 0 1 0 1 1 0	Ciphertext

DECRYPT

	1 1 0 1 0 1 1 0	Ciphertext
⊕	1 1 1 0 0 0 1 1	Secret Key
=	0 0 1 1 0 1 0 1	Plaintext

Transposition techniques*

1. Rows/Columns Transposition

- Plaintext letters written in rows
- Ciphertext obtained by reading column-by-column, but re-arranged
- Key determines order of columns to read
- Easy to break using letter frequency (try different column orders)
- Transposition ciphers can be made stronger by using multiple stages of transposition

Transposition techniques

1. Rows/Columns Transposition

```
Key:        4 3 1 2 5 6 7
Input:      t t n a a p t
            m t s u o a o
            d w c o i x k
            n l y p e t z
Output:     NSCYAUOPTTWLTMDNAOIEPAXTTOKZ
```

Measures of Security

- Unconditionally Secure
  - Ciphertext does not contained enough information to derive plaintext or key
  - One-time pad is only unconditionally secure cipher (but not very practical)

- Computationally Secure
  - If either:
    - Cost of breaking cipher exceeds value of encrypted information
    - Time required to break cipher exceeds useful lifetime of encrypted information
  - Hard to estimate value/lifetime of some information
  - Hard to estimate how much effort needed to break cipher

Examples of Brute-Force Attacks

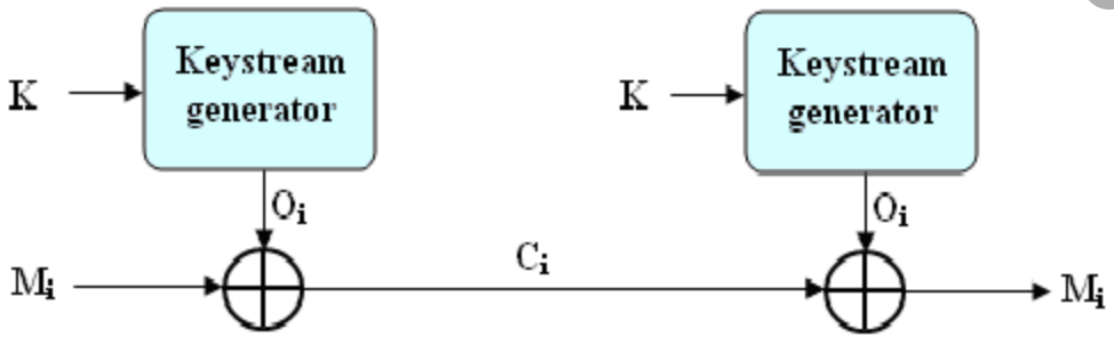
Key Size (bits)	Number of Alternative Keys	Time Required at 1 Decryption/μs	Time Required at 10^6 Decryptions/μs
32	$2^{32} = 4.3 \times 10^9$	$2^{31}\ \mu$s = 35.8 minutes	2.15 milliseconds
56	$2^{56} = 7.2 \times 10^{16}$	$2^{55}\ \mu$s = 1142 years	10.01 hours
128	$2^{128} = 3.4 \times 10^{38}$	$2^{127}\ \mu$s = 5.4×10^{24} years	5.4×10^{18} years
168	$2^{168} = 3.7 \times 10^{50}$	$2^{167}\ \mu$s = 5.9×10^{36} years	5.9×10^{30} years
26 characters (permutation)	$26! = 4 \times 10^{26}$	$2 \times 10^{26}\ \mu$s = 6.4×10^{12} years	6.4×10^6 years

Symmetric Encryption (*nowadays*)

- Stream cipher
  - The plain text is assumed as a sequence of bits with unknown length
- Block cipher
  - The plain text is assumed as a block of bits of fixed length (usually 64 or 128 bits)
    - Using padding if the information is not multiple of 64/128

Stream cipher

- Originate to One-Pad Time
  - But faster and with low complexity
  - Use of XOR operation in most of the cases
- It is an encryption algorithm that encrypts 1 bit or byte of plaintext at a time.
- It uses an infinite stream of pseudorandom bits as the key.
- For a stream cipher implementation to remain secure, its pseudorandom generator should be unpredictable and the key should never be reused. Use the same seed (K) on pseudorandom generator byte generator



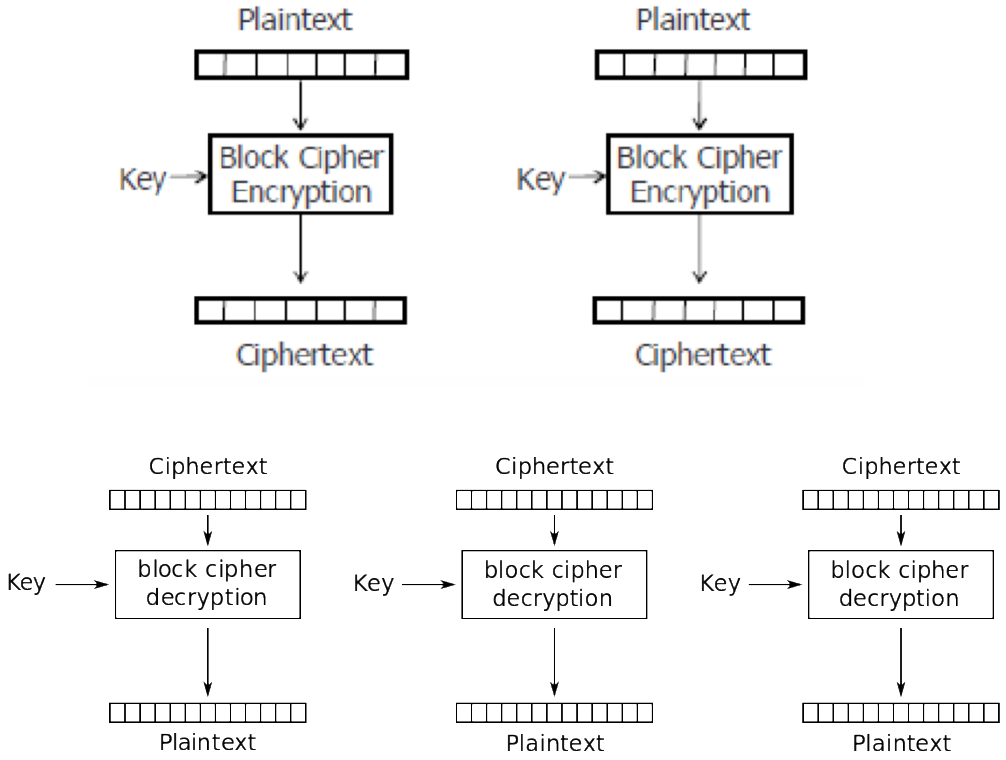
Stream cipher*

- **RC4 – a popular stream cipher**
  - RC4, which stands for Rivest Cipher 4, is the most widely used of all stream ciphers, particularly in software.
  - RC4 steam ciphers have been used in various protocols like WEP and WPA (both security protocols for wireless networks) as well as in TLS.
  - Unfortunately, recent studies have revealed vulnerabilities in RC4, prompting Mozilla and Microsoft to recommend that it be disabled where possible.
  - RFC 7465 prohibits the use of RC4 in all versions of TLS.

Block cypher

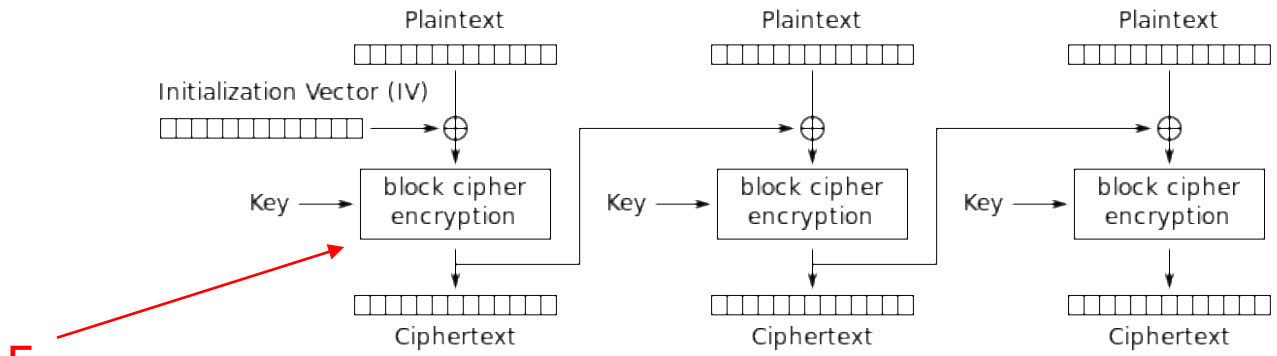
1. Electronic Code Book
2. Cipher Block Chaining
3. Chained Cipher Block Chaining
4. Output Feedback
5. Counter

Block cypher – Electronic Code Book*

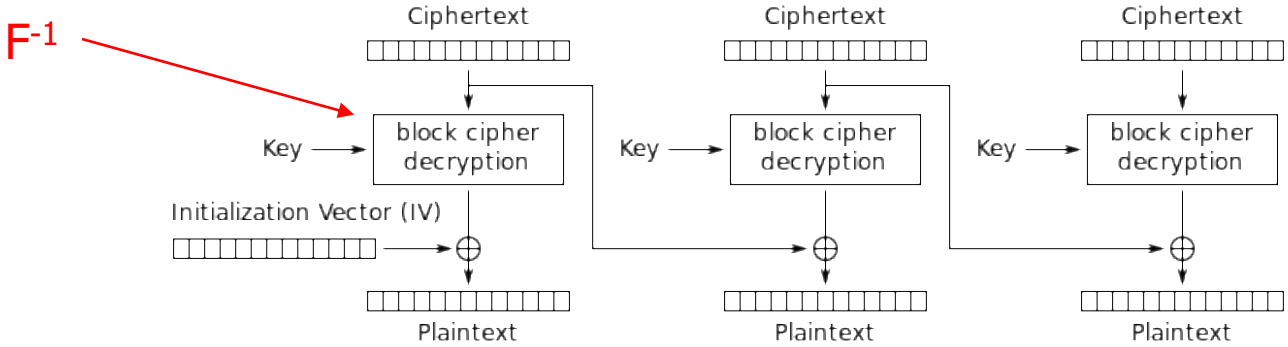


Electronic Codebook (ECB) mode decryption

Block cypher – Cipher Block Chaining



Cipher Block Chaining (CBC) mode encryption



Cipher Block Chaining (CBC) mode decryption

Block cypher – Cipher Block Chaining



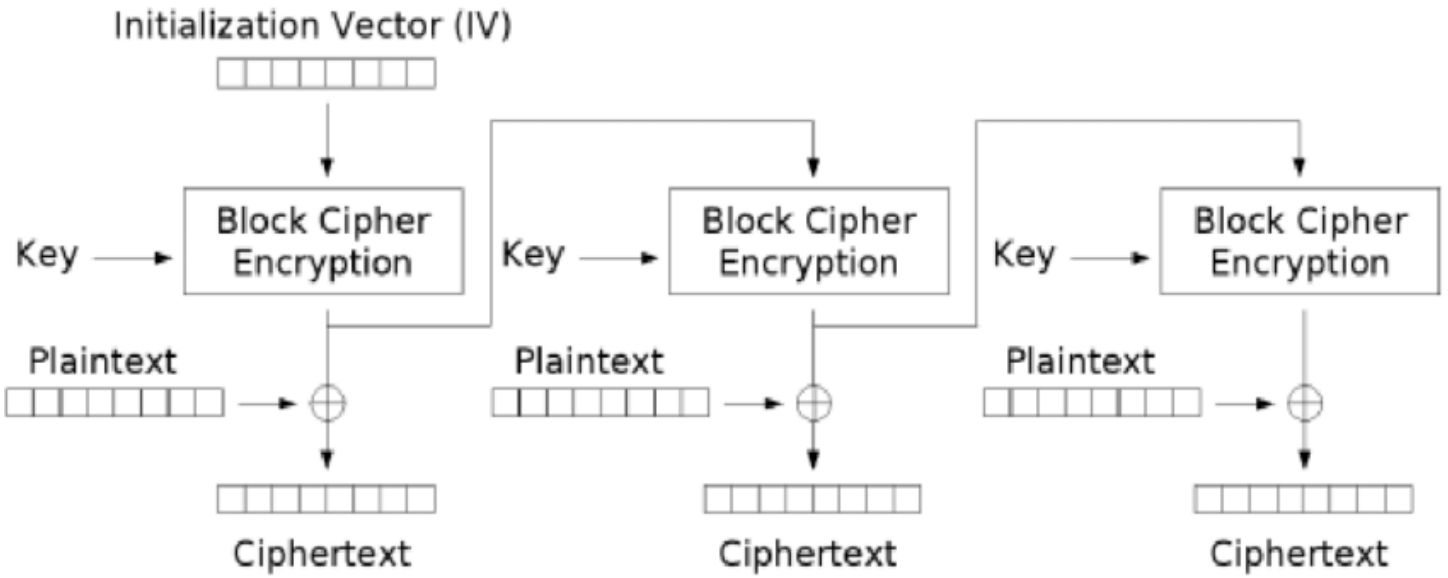
- Overcome the problem of plain text attacks as it needs an initialization vector
- On the other hand this initialization vector needs to be known by the receiver
- The decryption needs to be done in the some sequential order

Block cypher – Chained Cipher Block Chaining



- The initialization vector is only once.
- All the blocks use the previous cypher text.

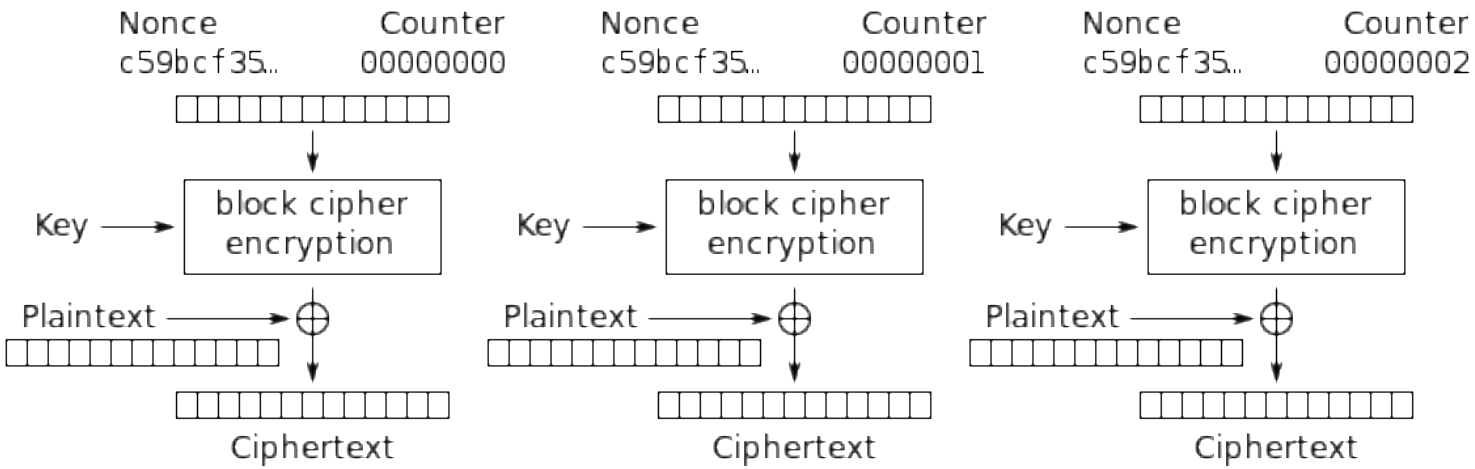
Block cypher – Output Feedback



-> We use the F for the decryption. We do not need the F^{-1}

-> This method is very fast as F can be calculated in advance

Block cypher – Counter



Counter (CTR) mode encryption

-> Faster than Output Feedback

Popular block ciphers

DES - Data Encryption Standard, used to be the most popular block cipher in the world and was used in several industries. It's still popular today, but only because it's usually included in historical discussions of encryption algorithms. The DES algorithm became a standard in the US in 1977. However, it's already been proven to be vulnerable to brute force attacks and other cryptanalytic methods. DES is a 64-bit cipher that works with a 64-bit key. Actually, 8 of the 64 bits in the key are parity bits, so the key size is technically 56 bits long.

3DES - based on DES. It's practically DES that's run three times. Each DES operation can use a different key, with each key being 56 bits long. Like DES, 3DES has a block size of 64 bits. Although 3DES is many times stronger than DES, it is also much slower (about 3x slower). Because many organizations found 3DES to be too slow for many applications, it never became the ultimate successor of DES. That distinction is reserved for the next cipher in our list - AES.

AES - Advanced Encryption Standard is arguably the most widely used block cipher in the world. It has a block size of 128 bits and supports three possible key sizes - 128, 192, and 256 bits. The longer the key size, the stronger the encryption. However, longer keys also result in longer processes of encryption. For a discussion on encryption key lengths, read Choosing Key Lengths for Encrypted File Transfers.

Blowfish - This is another popular block cipher (although not as widely used as AES). It has a block size of 64 bits and supports a variable-length key that can range from 32 to 448 bits. One thing that makes blowfish so appealing is that Blowfish is unpatented and royalty-free.

Twofish - it is related to Blowfish but it's not as popular (yet). It's a 128-bit block cipher that supports key sizes up to 256 bits long.

Symmetric Encryption

- Let's see now how the block cypher encryption works individually
- Symmetric Encryption models
  - **Substitution-Permutation Networks**
  - **Feistel Networks**
- Most of the key used are 128 or 256 bits

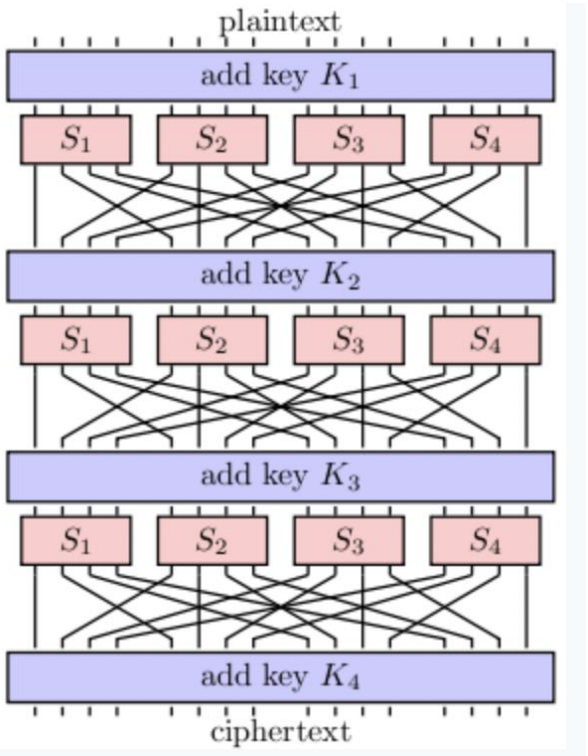
- Good encryption functions are when changing just one bit of plain text leads to a cipher text for which the probability of changing each of its bits is 50%.

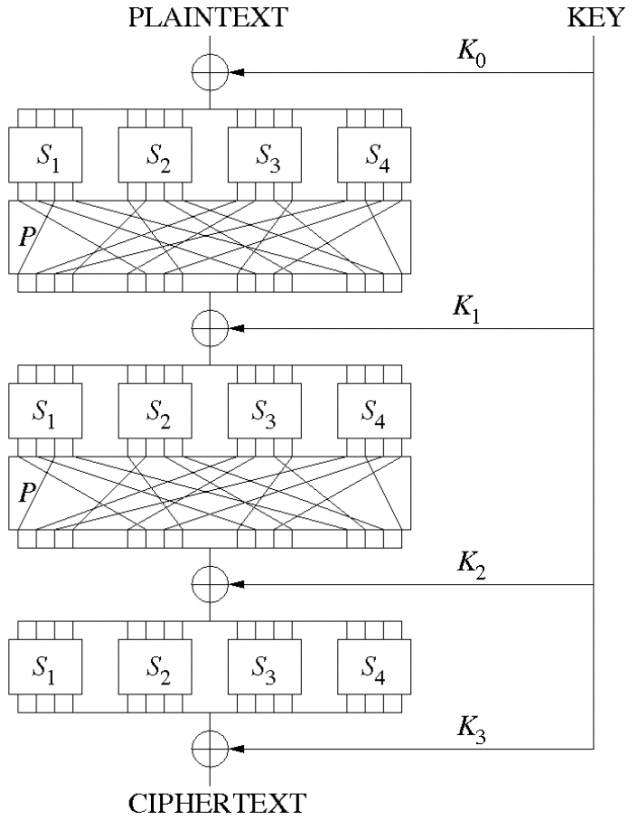
Block Ciphers Features

- Block size: in general *larger* block sizes mean *greater* security.
- Key size: *larger* key size means *greater* security (larger key space).
- Number of rounds: multiple rounds offer increasing security.
- Encryption modes: define how messages larger than the block size are encrypted, *very important* for the security of the encrypted message.

Substitution-Permutation Networks

- Substitution + Permutation tasks



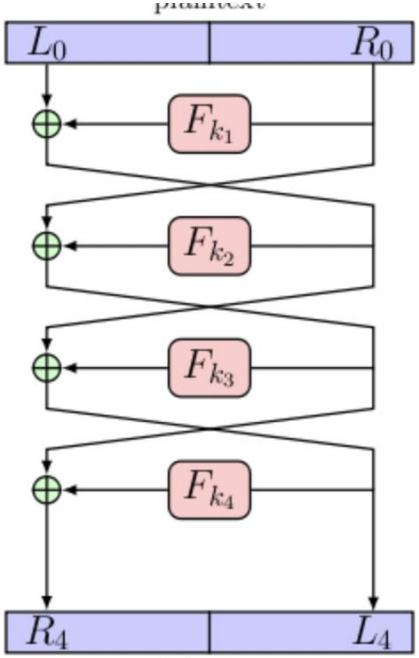


Sub keys generation

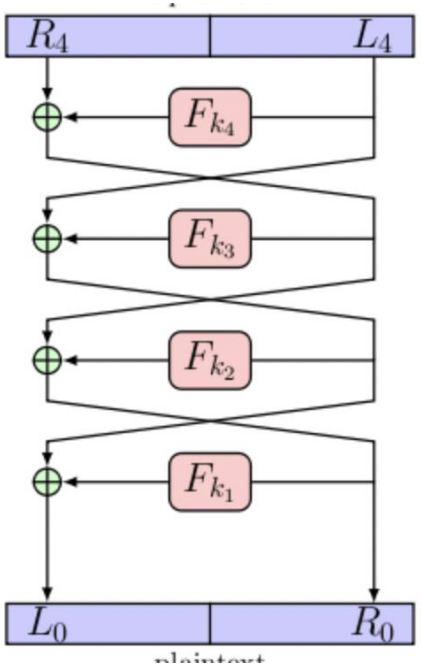
- The original key is used to generate the necessary sub-keys for each phase
- If we have **n** stages we need **n+1** sub-keys
  - After the last stage

Feistel Networks

- Encryption:



- Decryption:



Feistel Networks

- **Encryption**:
  - $L_1 = R_0 \quad R_1 = L_0 \oplus f_1(R_0)$
  - $L_2 = R_1 \quad R_2 = L_1 \oplus f_2(R_1)$
  - …
  - $L_d = R_{d-1} \quad R_d = L_{d-1} \oplus f_d(R_{d-1})$
- **Decryption**:
  - $R_{d-1} = L_d \quad L_{d-1} = R_d \oplus f_d(L_d)$
  - …
  - $R_0 = L_1; \quad L_0 = R_1 \oplus f_1(L_1)$

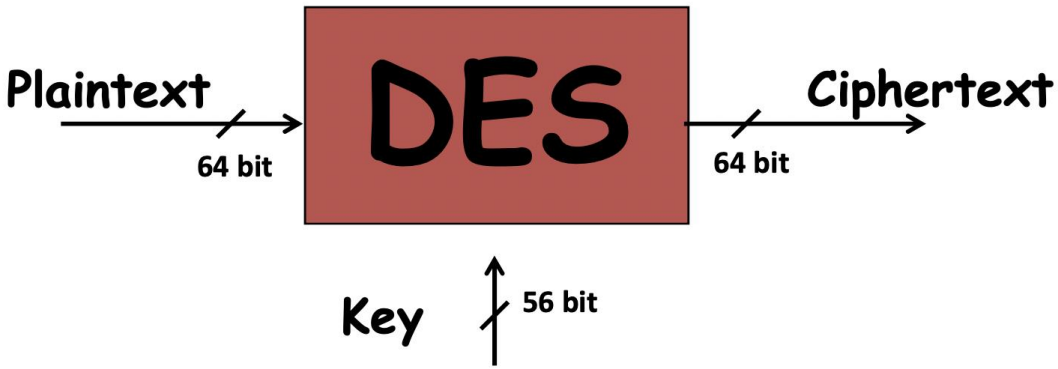
Data Encryption Standard (DES)

- Most widely used block cipher in the world
- Adopted in 1977 by National Bureau Standards (NBS)
- Encrypts 64-bit data using 56-bit key
- Has widespread use
- Has been considerable controversy over its security

Feistel Networks

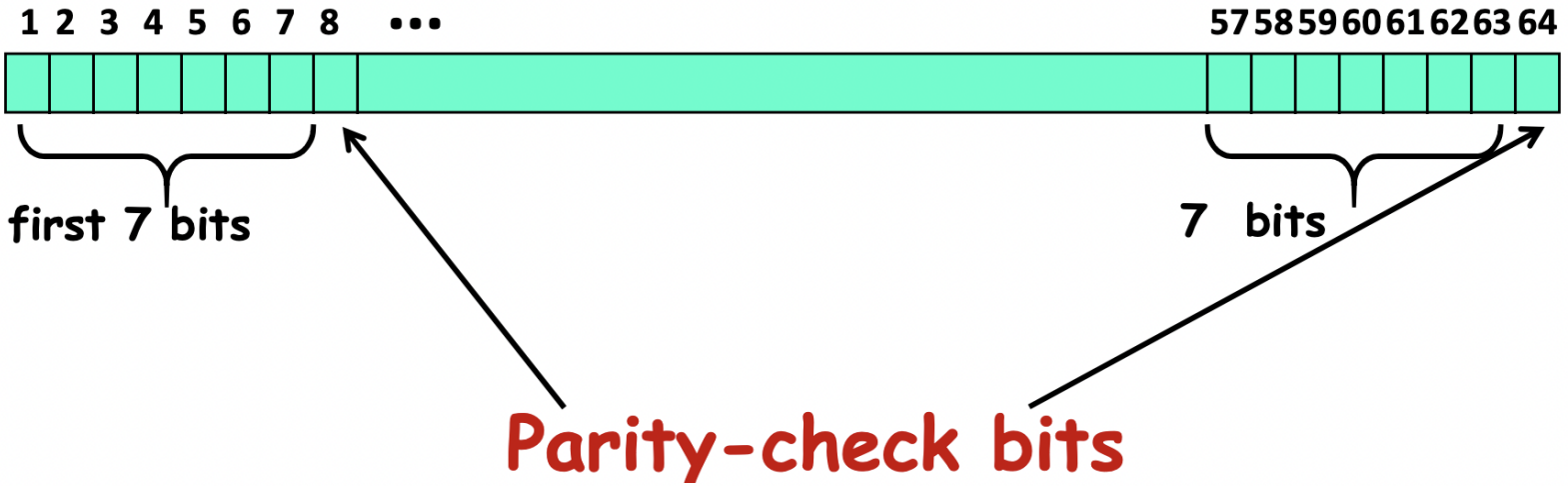
Data Encryption Standard (DES)

- Block size = 64 bits
- Key size = 56 bits (in reality, 64 bits, but 8 are used as parity-check bits for error control, see next slide)
- Number of rounds = 16
- 16 intermediary keys, each 48 bits



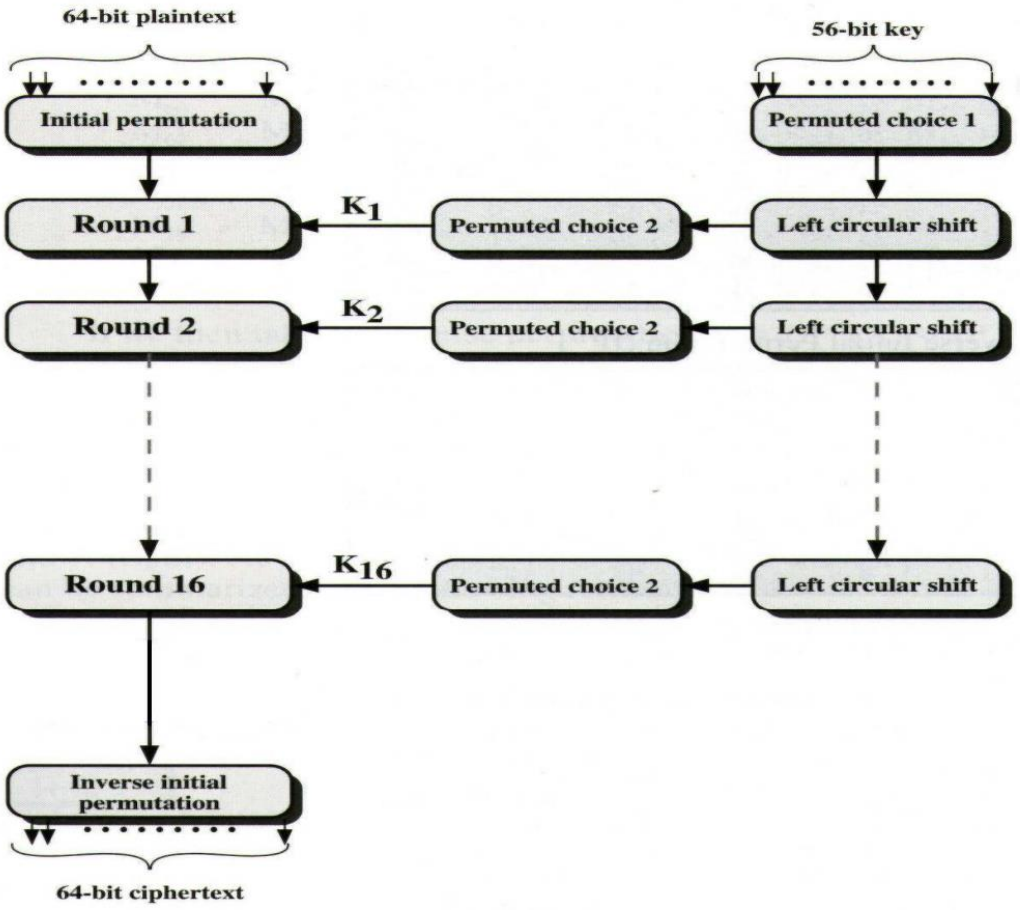
Key length in DES

- In the DES specification, the key length is 64 bit:
- 8 bytes; in each byte, the 8th bit is a parity-check bit



Each parity-check bit is the XOR of the previous 7 bits

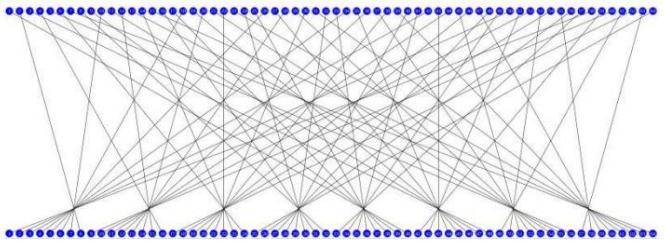
DES Rounds


64-bit plaintext
56-bit key
Initial permutation
Permuted choice 1
Round 1
K1
Permuted choice 2
Left circular shift
Round 2
K2
Permuted choice 2
Left circular shift
Round 16
K16
Permuted choice 2
Left circular shift
Inverse initial permutation
64-bit ciphertext

Data Encryption Standard (DES)*

- Initial permutation:

58	50	42	34	26	18	10	2
60	52	44	36	28	20	12	4
62	54	46	38	30	22	14	6
64	56	48	40	32	24	16	8
57	49	41	33	25	17	9	1
59	51	43	35	27	19	11	3
61	53	45	37	29	21	13	5
63	55	47	39	31	23	15	7



- This table specifies the input permutation on a 64-bit block.
- The meaning is as follows:
  - the first bit of the output is taken from the 58th bit of the input; the second bit from the 50th bit, and so on, with the last bit of the output taken from the 7th bit of the input.
- This information is presented as a table for ease of presentation:
  - it is a vector, not a matrix.

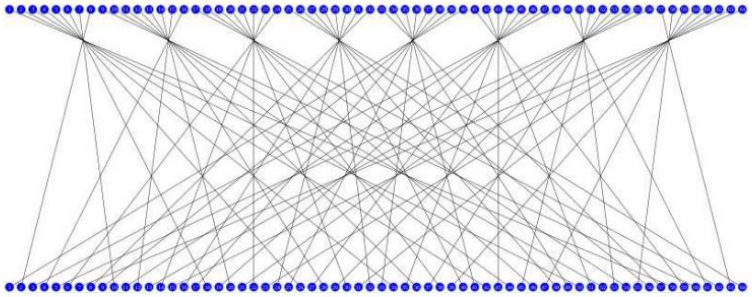
12

* https://www.lri.fr/~fmartignon/documenti/systemesecurite/4-DES.pdf

Data Encryption Standard (DES)*

- Final permutation:

40	8	48	16	56	24	64	32
39	7	47	15	55	23	63	31
38	6	46	14	54	22	62	30
37	5	45	13	53	21	61	29
36	4	44	12	52	20	60	28
35	3	43	11	51	19	59	27
34	2	42	10	50	18	58	26
33	1	41	9	49	17	57	25

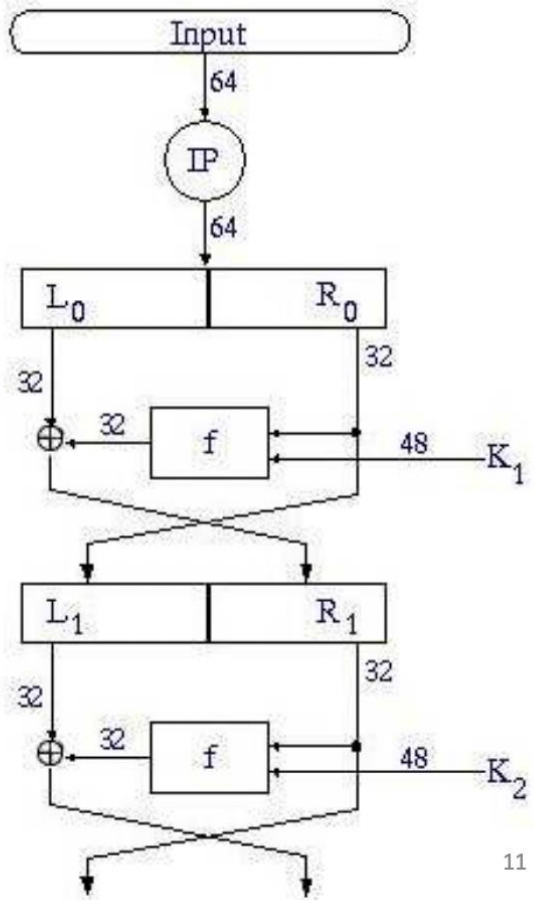


- The final permutation is the *inverse* of the initial permutation; the table is interpreted similarly.
  - That is, the output of the *Final Permutation* has bit 40 of the preoutput block as its first bit, bit 8 as its second bit, and so on, until bit 25 of the preoutput block is the last bit of the output.

DES Details*

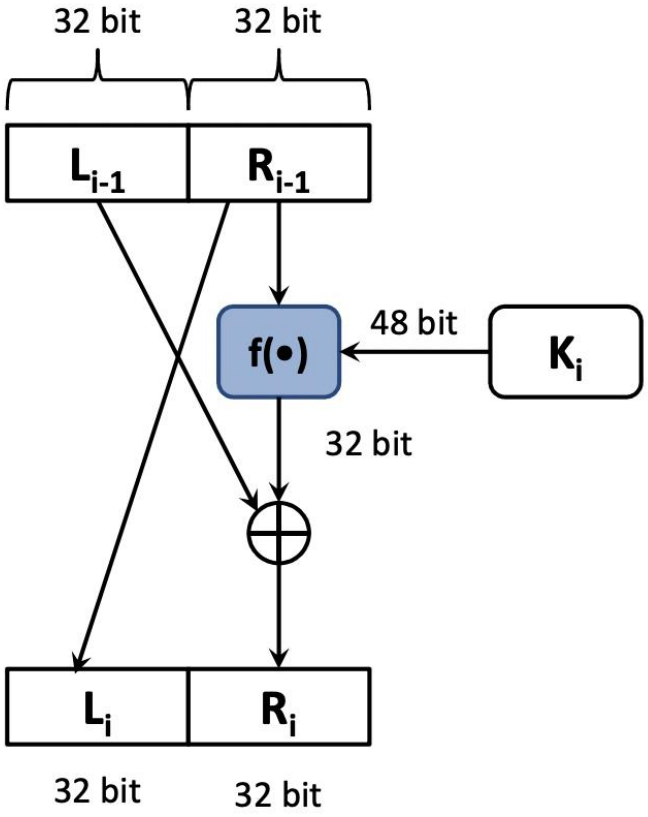
- $IP(x) = L_0R_0$
- $L_i = R_{i-1}$
- $R_i = L_{i-1} \oplus f(R_{i-1}, K_i)$
- $y = IP^{-1}(R_{16}L_{16})$

Note: IP means Initial Permutation



DES Round i*

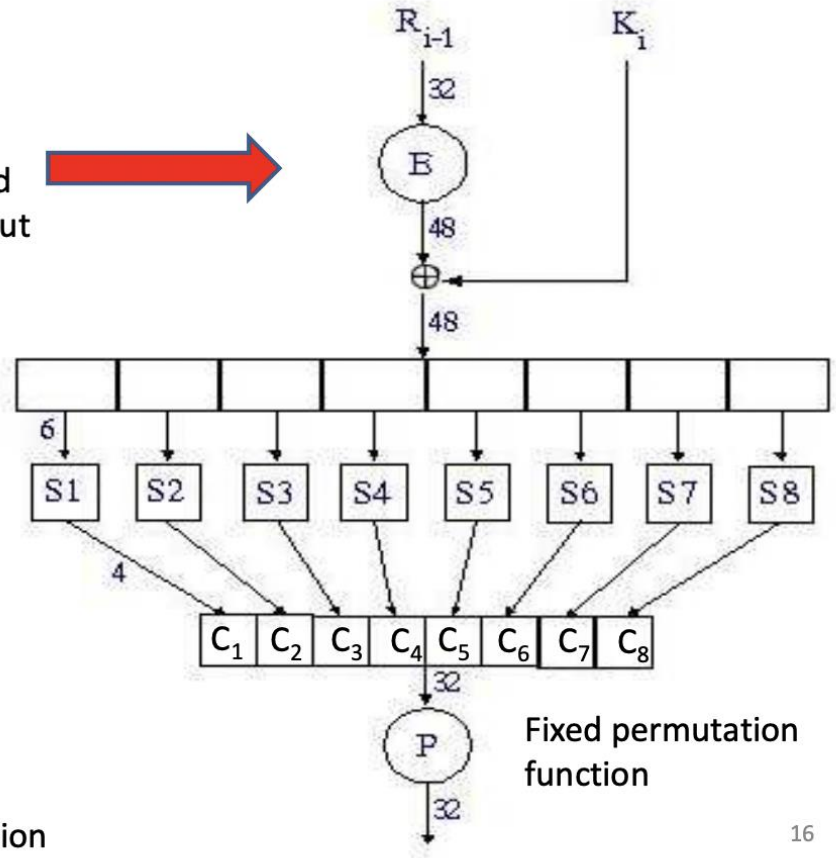
- $L_i = R_{i-1}$
- $R_i = L_{i-1} \oplus f(R_{i-1}, K_i)$



DES "f(•)" Function *

E is an *expansion function* which takes a block of 32 bits as input and produces a block of 48 bits as output

32	1	2	3	4	5
4	5	6	7	8	9
8	9	10	11	12	13
12	13	14	15	16	17
16	17	18	19	20	21
20	21	22	23	24	25
24	25	26	27	28	29
28	29	30	31	32	1



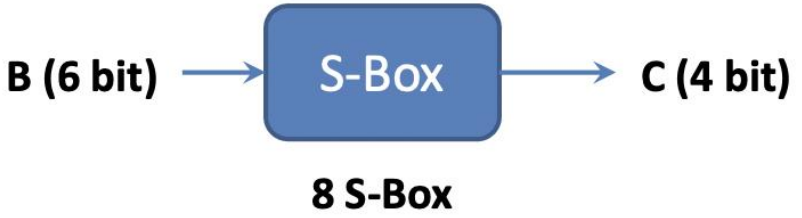
Fixed permutation function

16 bits appear twice, in the expansion

S-boxes*

- S-boxes are the only *non-linear* elements in DES design

Each of the unique selection functions $S_1, S_2, \ldots, S_8$, takes a 6-bit block as input and yields a 4-bit block as output



- S = matrix 4x16, values from 0 to 15
- B (6 bit long) = $b_1 b_2 b_3 b_4 b_5 b_6$
  - $b_1 b_6$ ➔ r = row of the matrix (2 bits: 0,1,2,3)
  - $b_2 b_3 b_4 b_5$ ➔ c = column of the matrix (4 bits:0,1,…15)
- C (4 bit long) = Binary representation of S(r, c)

Example (S1)*

Row #	S_1	1	2	3	...	7								15	Column #
0	14	4	13	1	2	15	11	8	3	10	6	12	5	9	0	7
1	0	15	7	4	14	2	13	1	10	6	12	11	9	5	3	8
2	4	1	14	8	13	6	2	11	15	12	9	7	3	10	5	0
3	15	12	8	2	4	9	1	7	5	11	3	14	10	0	6	13

S(i, j) <16, can be represented with 4 bits

Example: B =101111

b_1b_6 = 11 = row 3

$b_2b_3b_4b_5$= 0111 = column 7

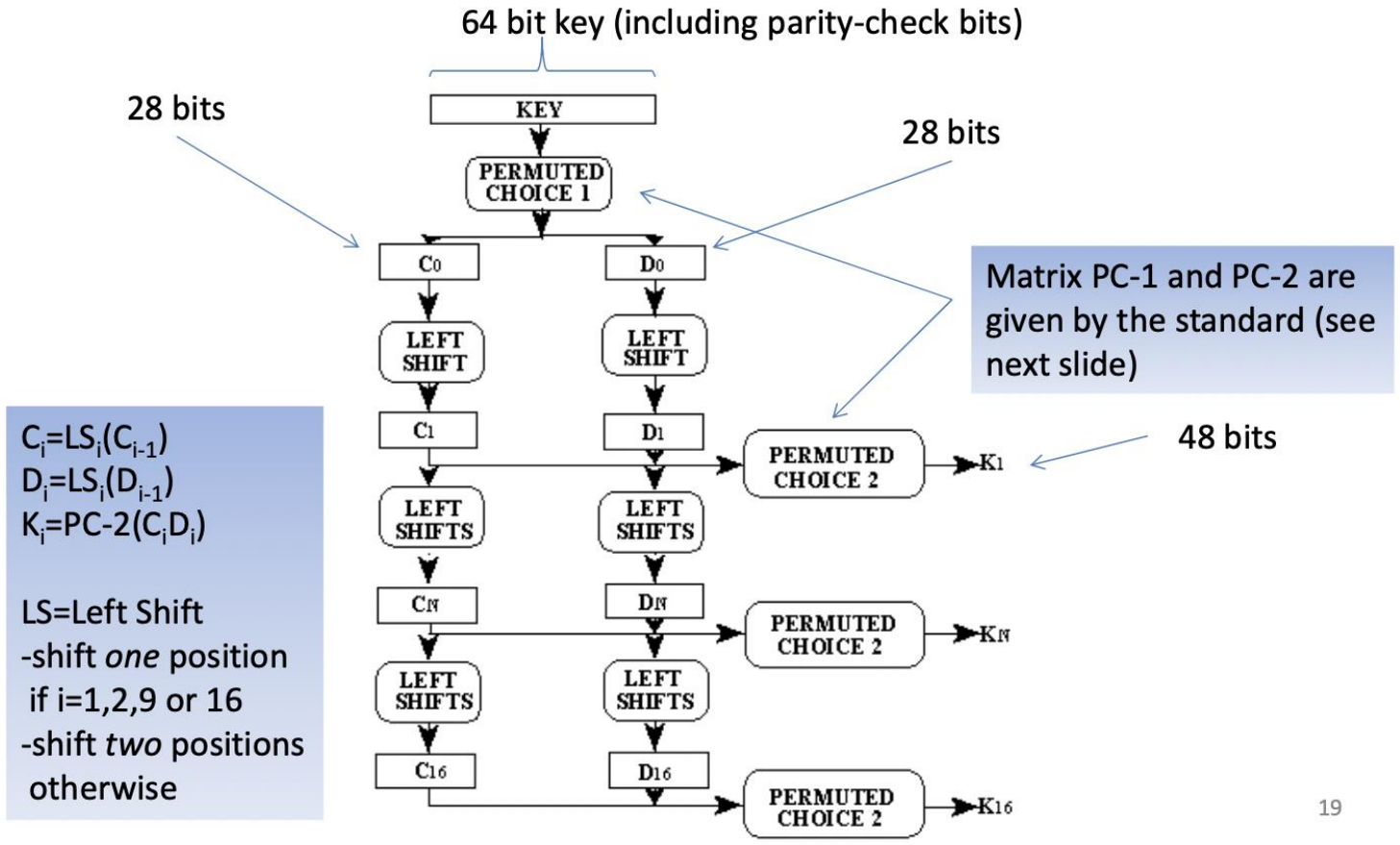


C=7=0111

Another example: B=011011, C=?

18

DES Key Generation (K_1 – K_{16})*



DES Permuted Choice 1 and 2 (PC-1, PC-2)

Parity-check bits (namely, bits 8,16, 4,32,40,48,56,64) are not chosen, they do not appear in **PC-1**

Left						
57	49	41	33	25	17	9
1	58	50	42	34	26	18
10	2	59	51	43	35	27
19	11	3	60	52	44	36
Right						
63	55	47	39	31	23	15
7	62	54	46	38	30	22
14	6	61	53	45	37	29
21	13	5	28	20	12	4

14	17	11	24	1	5	3	28
15	6	21	10	23	19	12	4
26	8	16	7	27	20	13	2
41	52	31	37	47	55	30	40
51	45	33	48	44	49	39	56
34	53	46	42	50	36	29	32

PC-2 selects the 48-bit subkey for each round from the 56-bit key-schedule state

DES Weak Keys*

- DES uses 16 48-bits keys generated from a master 56-bit key (64 bits if we consider also parity bits)
- Weak keys: keys make the same sub-key to be generated in more than one round.
- Result: reduce cipher complexity
- Weak keys can be avoided at key generation.
- DES has 4 weak keys
  - 01010101 01010101
  - FEFEFEFE FEFEFEFE
  - E0E0E0E0 F1F1F1F1
  - 1F1F1F1F 0E0E0E0E



DES – alternatives

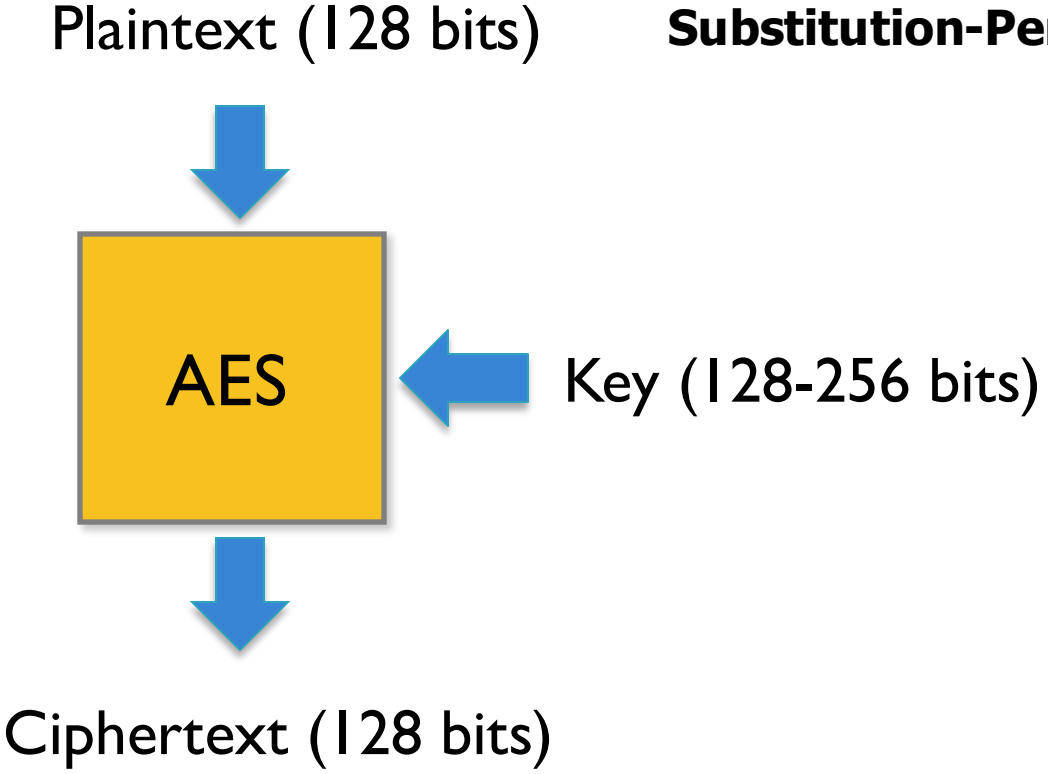
- TripleDES
  - Block length = 64 bits (as DES)
  - 3*DES with k1, k2, k3
  - Key length = 3* 56 bits = 168 bits (practical 112 bits)
  - Lifetime estimated = 2030
- AES

Advanced Encryption Standard (AES)

- Published by NIST in Nov 2001 FIPS PUB 197
- Based on a competition won by Rijmen and Daemen (Rijndael) from Belgium
- 22 submissions, 7 did not satisfy all requirements15 submissions 5 finalists Mars, RC6, Rijndael, Serpent, Twofish. Winner Rijndael.
- Rijndael allows many block sizes and key sizes
- AES restricts it to
- Block Size 128 bits
- Key sizes 128, 192, 256 (AES-128, AES-192, AES-256)
- An iterative rather than Feistel cipher
- operates on entire data block in every round
- Byte operations Easy to implement in software

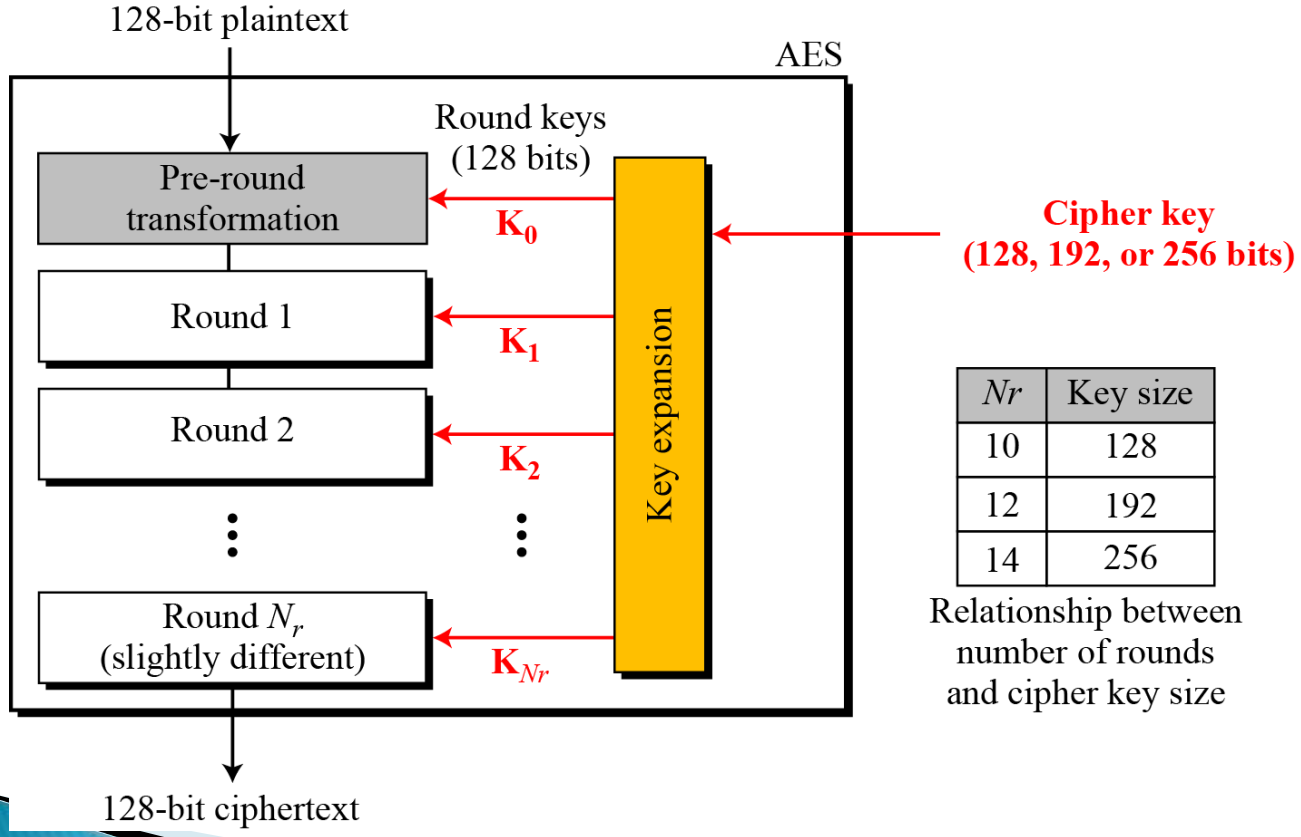
Substitution-Permutation

AES Conceptual Scheme



Multiple rounds

- Rounds are (almost) identical
  - First and last round are a little different

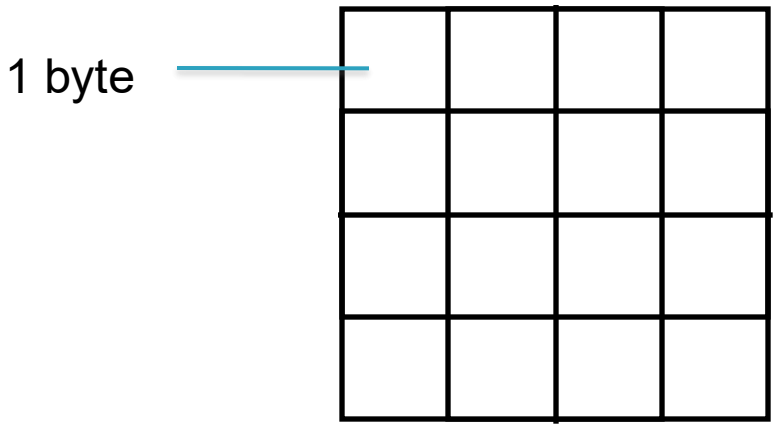


Nr	Key size
10	128
12	192
14	256

Relationship between number of rounds and cipher key size

128-bit values

- Data block viewed as 4-by-4 table of bytes
- Represented as 4 by 4 matrix of 8-bit bytes.
- Key is expanded to array of 32 bits words



High Level Description

Key Expansion

- Round keys are derived from the cipher key using Rijndael's key schedule

Initial Round

- AddRoundKey : Each byte of the state is combined with the round key using bitwise xor

Rounds

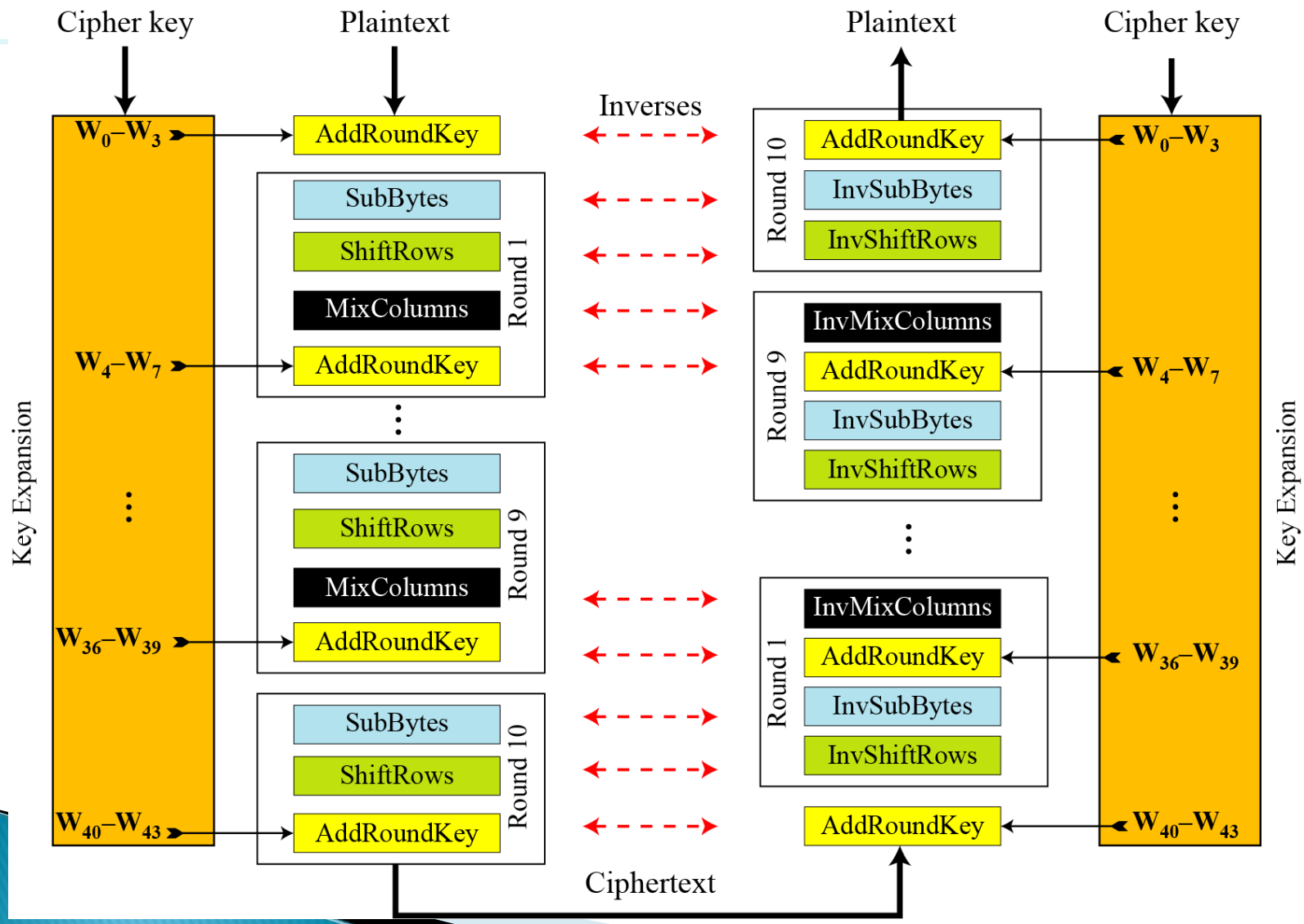
- SubBytes : non-linear substitution step
- ShiftRows : transposition step
- MixColumns : mixing operation of each column.
- AddRoundKey

Final Round

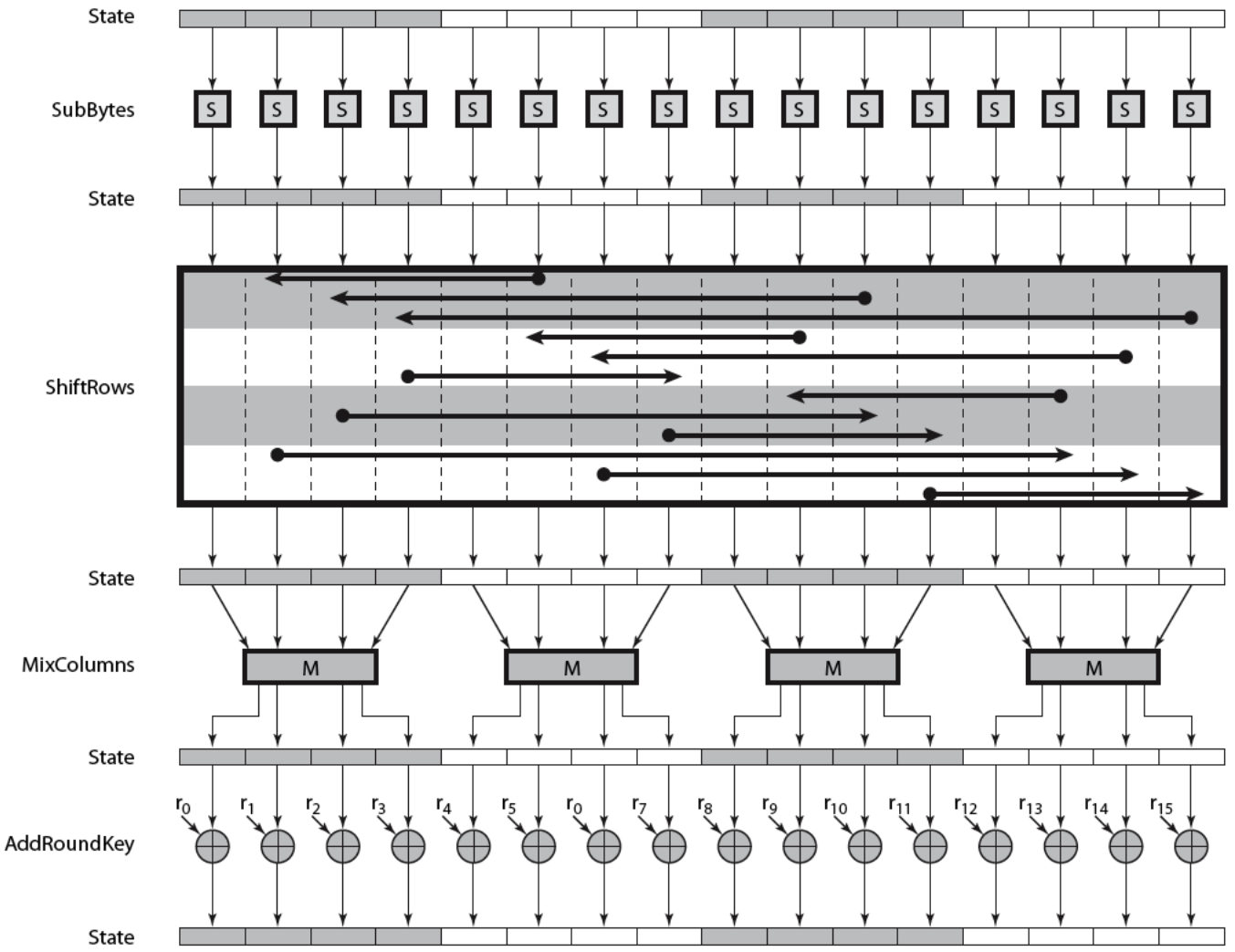
- SubBytes
- ShiftRows
- AddRoundKey

No MixColumns

Overall Structure



AES Round

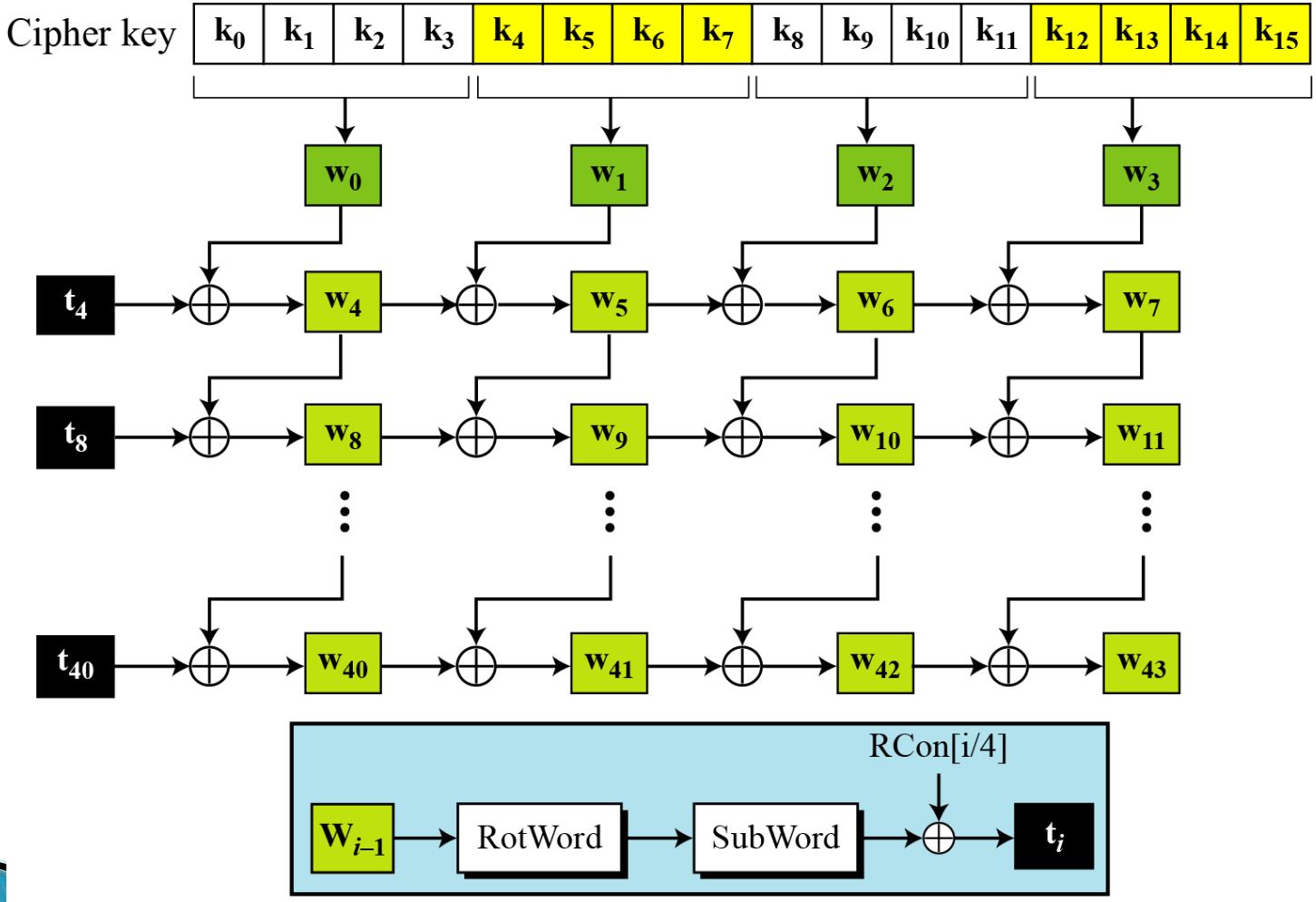

State
SubBytes
S
State
ShiftRows
State
MixColumns
M
State
AddRoundKey
r_0 r_1 r_2 r_3 r_4 r_5 r_0 r_7 r_8 r_9 r_{10} r_{11} r_{12} r_{13} r_{14} r_{15}
State

AES Key Scheduling

- takes 128-bits (16-bytes) key and expands into array of 44 32-bit words

Round	*Words*			
Pre-round	$\mathbf{w}_0$	$\mathbf{w}_1$	$\mathbf{w}_2$	$\mathbf{w}_3$
1	$\mathbf{w}_4$	$\mathbf{w}_5$	$\mathbf{w}_6$	$\mathbf{w}_7$
2	$\mathbf{w}_8$	$\mathbf{w}_9$	$\mathbf{w}_{10}$	$\mathbf{w}_{11}$
. . .	. . .			
N_r	$\mathbf{w}_{4N_r}$	$\mathbf{w}_{4N_r+1}$	$\mathbf{w}_{4N_r+2}$	$\mathbf{w}_{4N_r+3}$

Key Expansion Scheme



Making of t_i (temporary) words $i = 4\ N_r$

AES Security

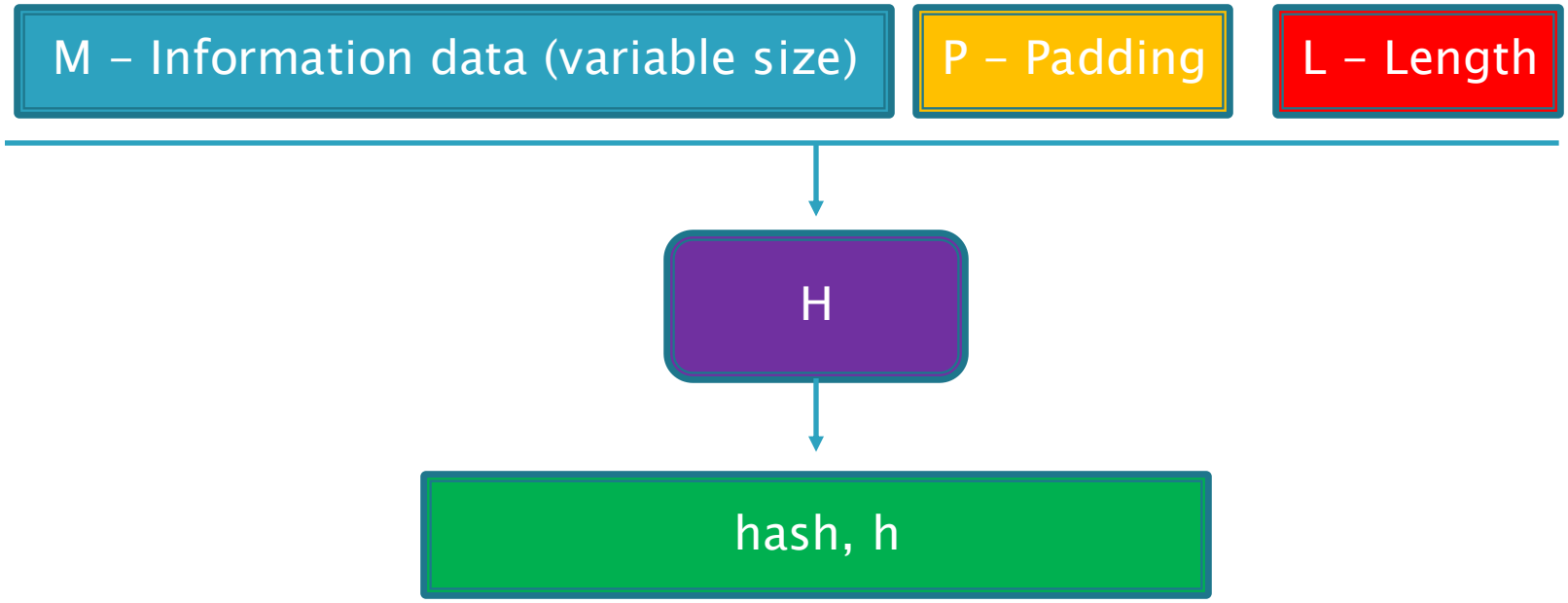
- AES was designed after DES.
- Most of the known attacks on DES were already tested on AES.
- Brute-Force Attack
  - AES is definitely more secure than DES due to the larger-size key.
- Statistical Attacks
  - Numerous tests have failed to do statistical analysis of the ciphertext
- Differential and Linear Attacks
  - There are no differential and linear attacks on AES as yet.

Implementation Aspects



- The algorithms used in AES are so simple that they can be easily implemented using cheap processors and a minimum amount of memory
- Very efficient
- Implementation was a key factor in its selection as the AES cipher

HASH functions



- A hash function usually means a function that compresses, meaning the output is shorter than the input.
- Padding is necessary as the input is usually of fixed size. L – to know the length of M
- The hash value is representative of the original input.
- A hash function can be used to create a finger printing. It 's almost impossible to alter the file without altering its hash value.

HASH functions

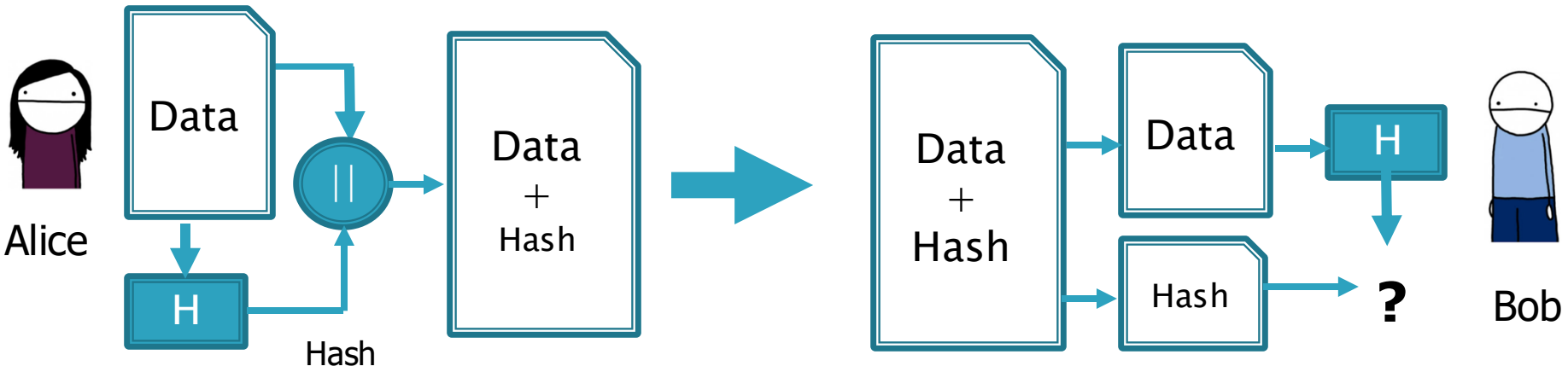
- Main objective: Data Integrity
- h = H(M)
- Size (M || P || L) = k*b

b – base value
k – integer value

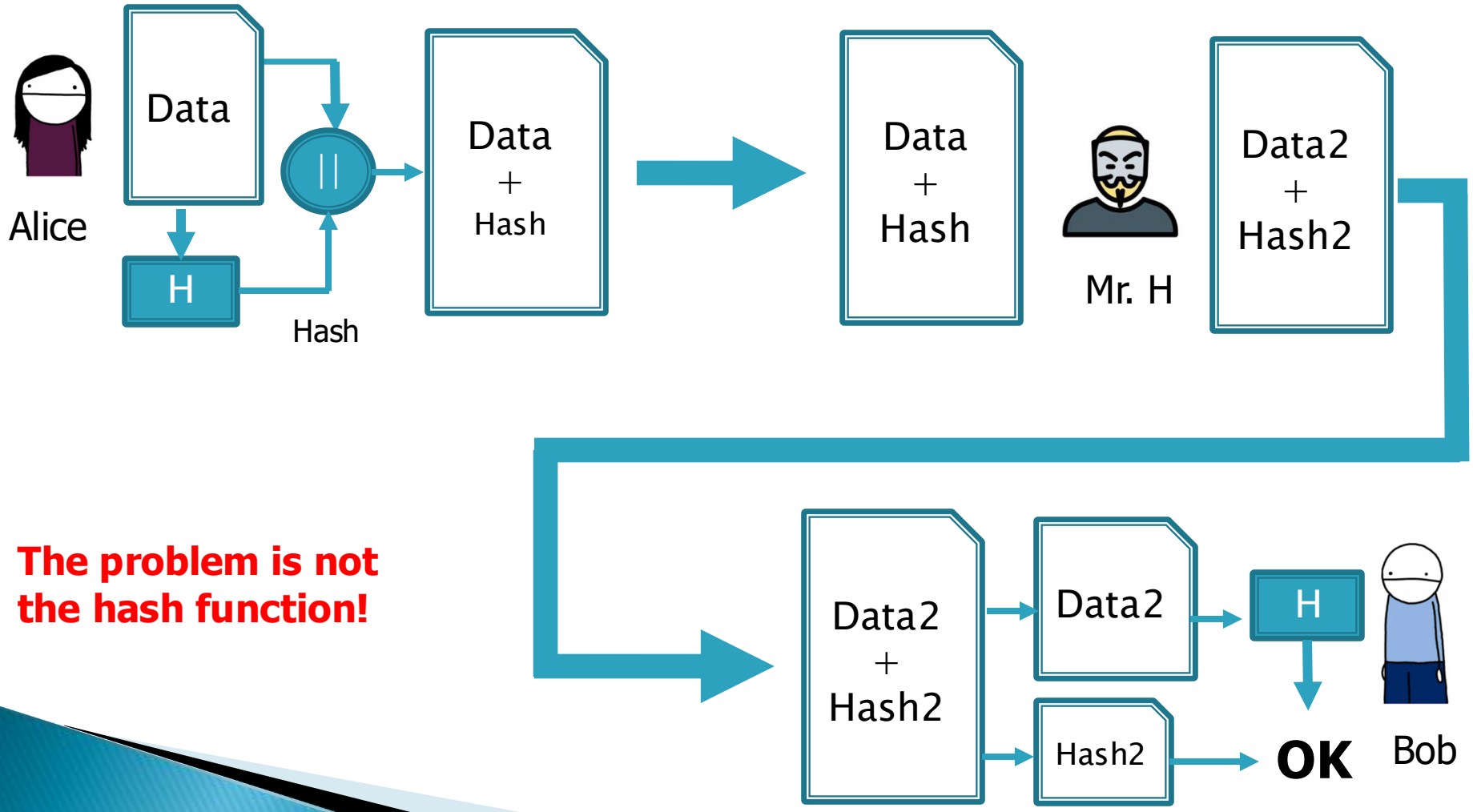
HASH functions

Requirement	Description
Variable input size	H can be applied to a block of data of any size.
Fixed output size	H produces a fixed-length output.
Efficiency	$H(x)$ is relatively easy to compute for any given x, making both hardware and software implementations practical.
Preimage resistant (one-way property)	For any given hash value h, it is computationally infeasible to find y such that $H(y) = h$.
Second preimage resistant (weak collision resistant)	For any given block x, it is computationally infeasible to find $y \neq x$ with $H(y) = H(x)$.
Collision resistant (strong collision resistant)	It is computationally infeasible to find any pair (x, y) with $x \neq y$, such that $H(x) = H(y)$.
Pseudorandomness	Output of H meets standard tests for pseudorandomness.

Applications of Hash functions – Integrity



Man-in-the-middle attack



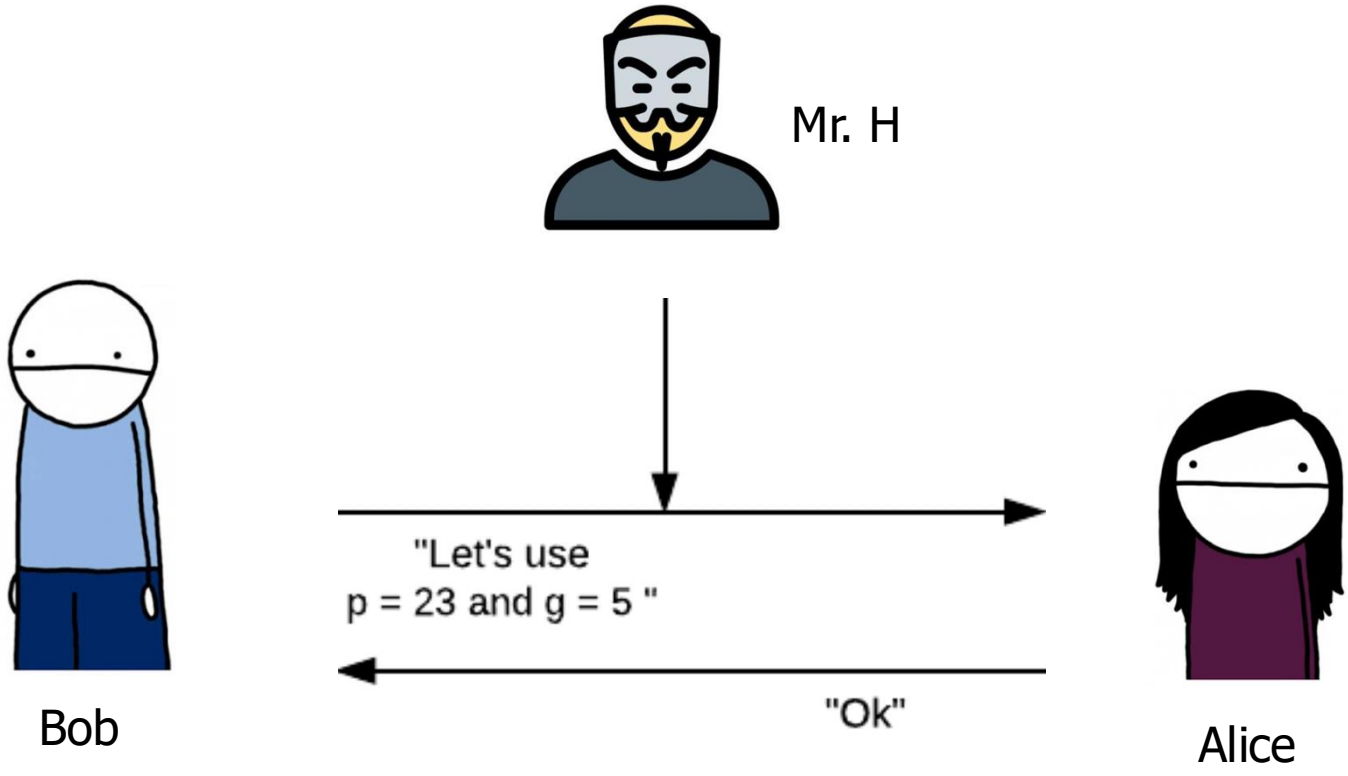
The problem is not the hash function!

Diffie-Hellman-Merkle



- **Diffie-Hellman-Merkle is a way to share a secret key with someone (or something) without actually sending them the key.**
  - U.S. Patent 4,200,770, from 1977

Diffie-Hellman (step 1)



Diffie-Hellman (step 2)

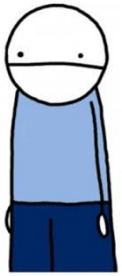


Mr. H



Alice

4



Bob

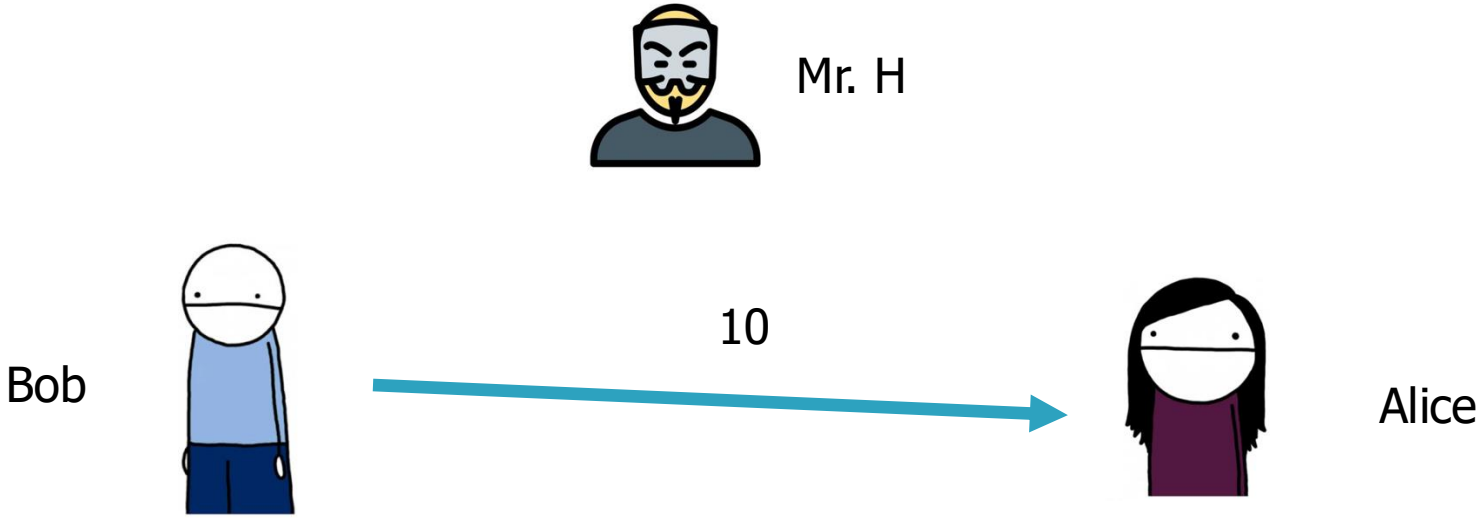
2. Alice needs to calculate a private key.

She does this by picking a secret number (a). She computes $G^a \ mod \ p$ and sends that result to Bob.

Alice chooses a secret, random integer a = 4.

Alice computes $A = 5^4 \ mod \ 23 = 4$ and sends the number 4 to Bob.

Diffie-Hellman (step 3)



3. Bob makes his own private key.

He calculates this by picking a secret number (b) and computing $g^b \ mod \ p$. He then sends the result to Alice. Bob creates a random private key, for this example we'll use 3.

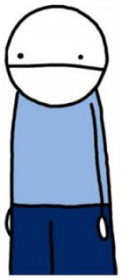
Then Bob calculates $B = 5^3 \ mod \ 23 = 10$ and sends 10 to Alice.

Diffie-Hellman (step 4)



Mr. H

Bob





Alice

4. Now Bob takes the number Alice sent him and computes $b^a \ mod \ p$.

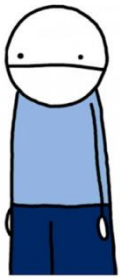
Bob computes $s = 4^3 \ mod \ 23 \ = 18$

Diffie-Hellman (step 5)



Mr. H

Bob





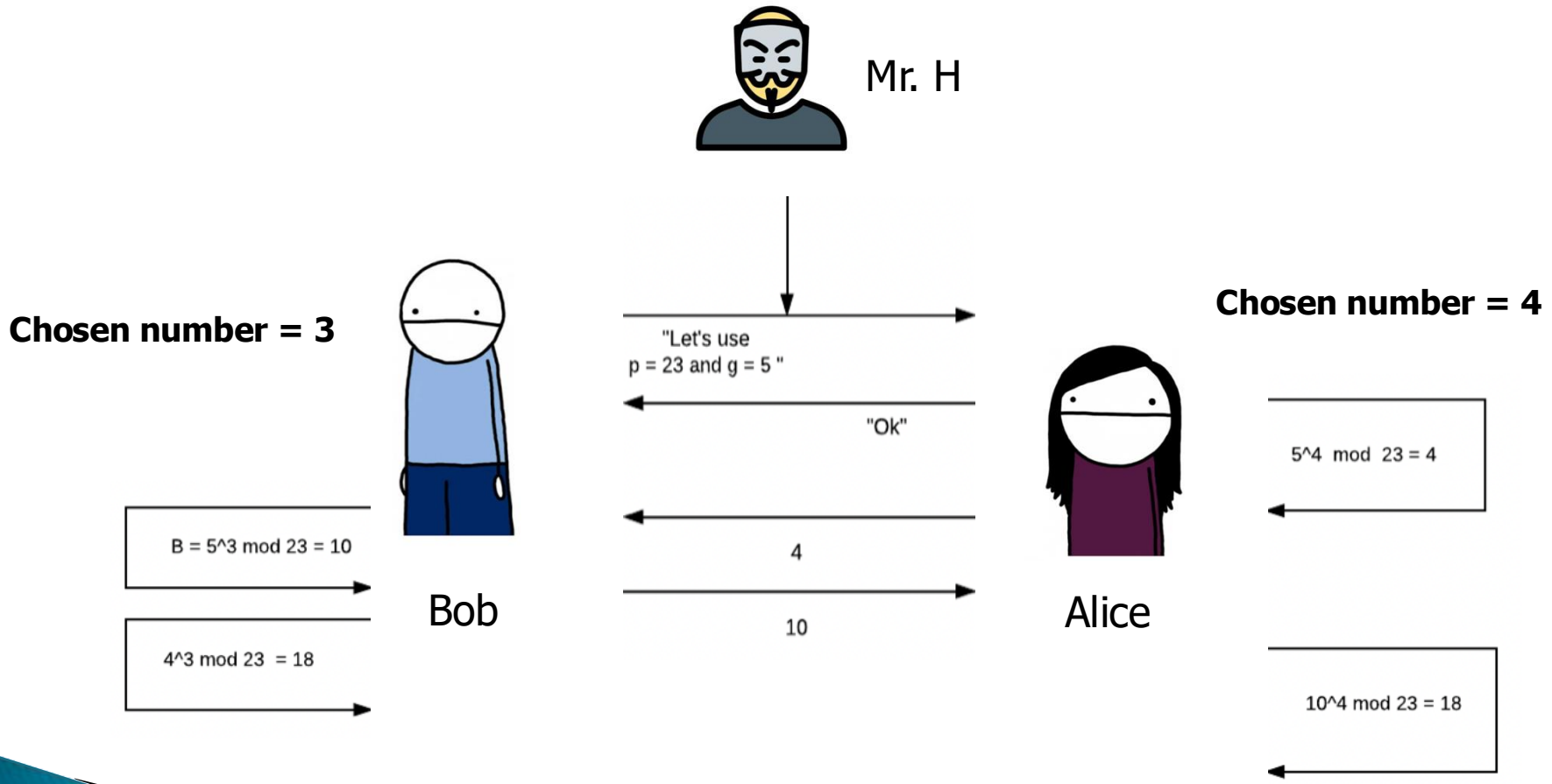
Alice

5. Alice computes $A^b \ mod \ p$.

Alice calculates $s = 10^4 \ mod \ 23 = 18$

The magic is that Alice and Bob now have the same number,

Diffie-Hellman (all steps)





Questions?